
Zero Trust Architecture

너무나도 다양한 사이버 공격

편리성을 위해 보안성을 약화
→ 바로 새로운 공격 기법이 탄생

10000번 막아도 1번만 뚫리면...

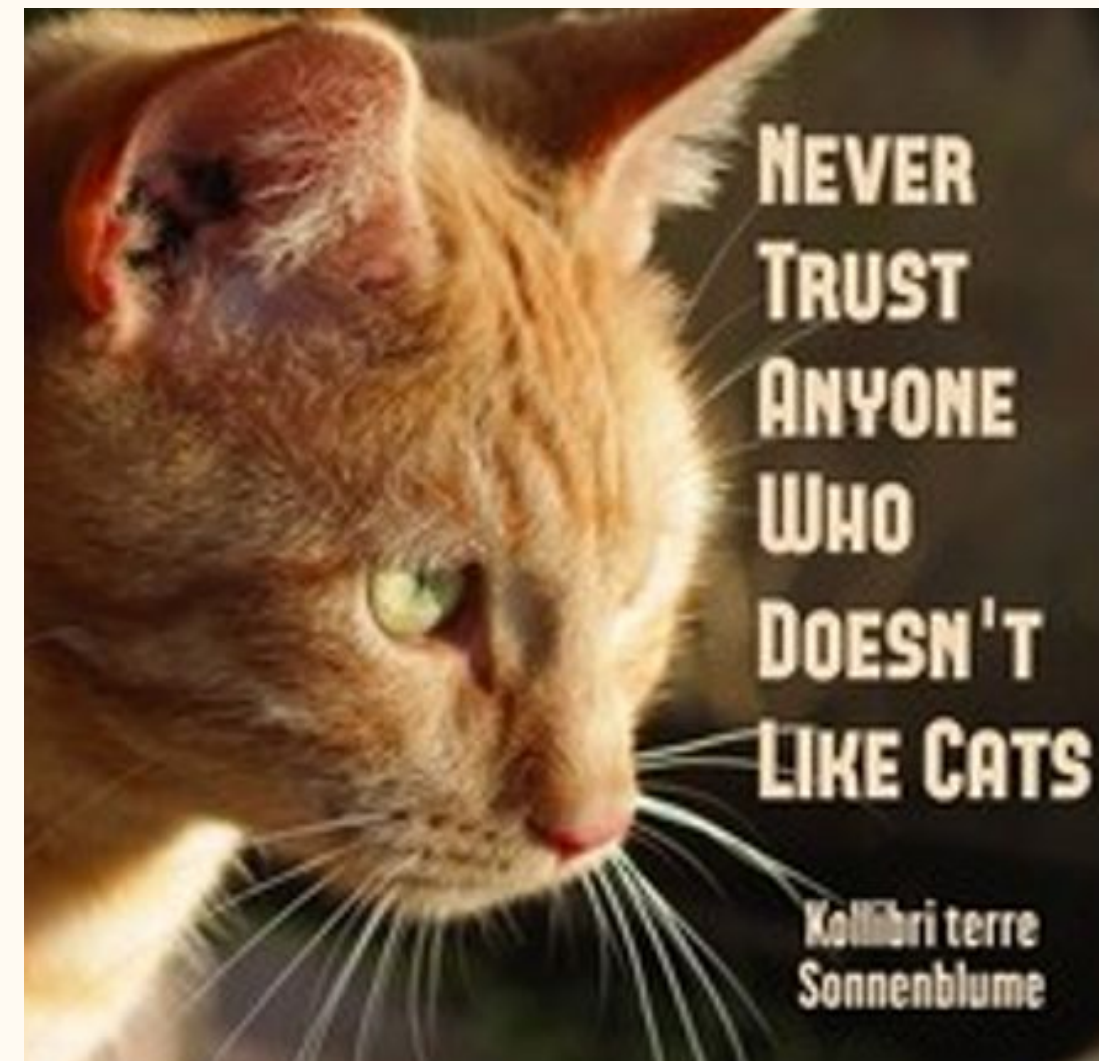


Zero Trust Architecture

"절대 신뢰하지 말고 상시 검증하라(Never Trust, Always Verify)"

제로 트러스트는 "모든 접속을 의심하고 검증한다"는 철학을 기반으로 하는 보안 모델.

즉, 네트워크 안과 밖의 경계를 구분하지 않고 모든 접속에 대해 지속적인 인증과 권한 확인을 요구



핵심 원칙들

항상 검증 (Always Verify)

네트워크 접속 요청이 내부에서 발생하든 외부에서 발생하든 항상 인증 및 권한 확인을 합니다.

침해 가정(Assume Breach)

“우리 시스템은 언젠가, 혹은 이미 공격당했다”고 가정한 상태에서 설계하는 보안 전략

최소 권한 원칙 (Least Privilege Access)

사용자는 필요한 최소한의 권한만을 부여받으며, 그 권한은 실시간으로 검증됩니다.

세분화된 접근 통제 (Micro-Segmentation)

네트워크를 작은 단위로 나누어 각 세그먼트마다 개별적으로 보안을 적용합니다.

주요 구성 요소

IAM (Identity and Access Management)

강력한 인증 시스템을 통해 사용자의 신원을 철저히 확인.



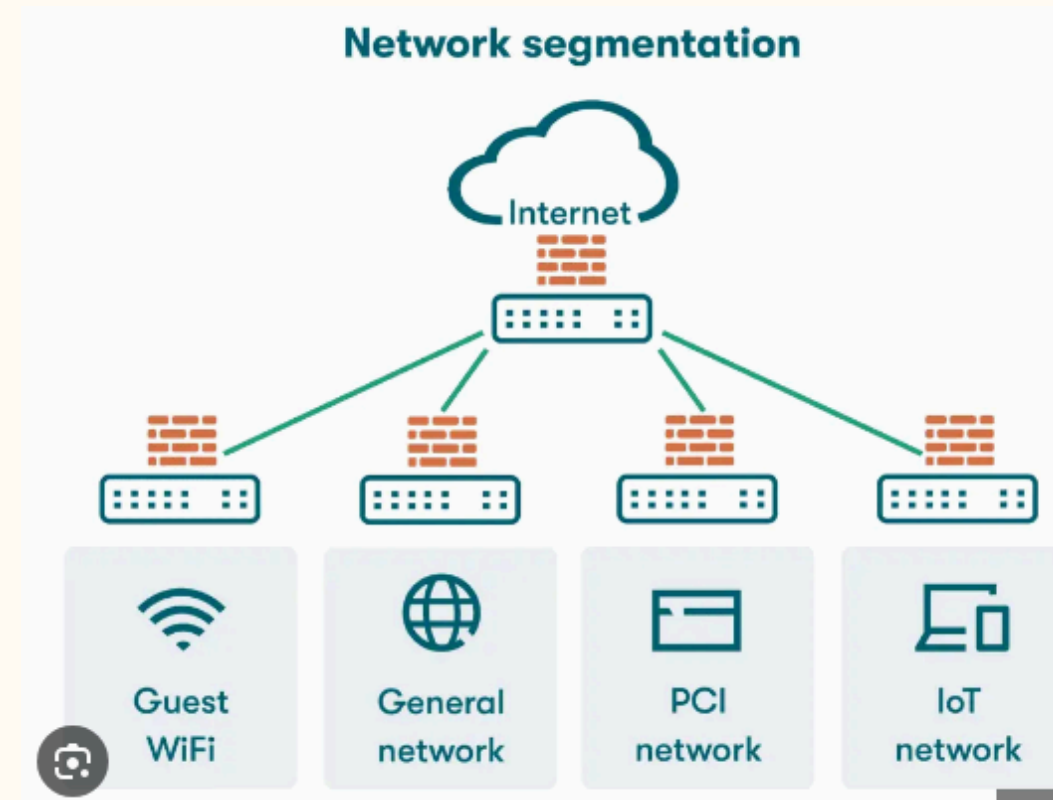
멀티팩터 인증(MFA): 사용자 인증 시 비밀번호 외에도 두 가지 이상의 인증 요소를 요구.

주요 구성 요소

네트워크 세분화 (Network Segmentation)

네트워크를 더 작고 격리된 세그먼트로 분할하여 잠재적인 사이버 공격의 측면 이동을 **제한**

네트워크 세분화를 통해
네트워크의 각 영역에
맞춤형 보안 정책을 적용



분산? → 보안성 높음
기본적인 원칙

주요 구성 요소

엔드포인트 및 데이터 보호 (Endpoint Protection)

비즈니스 전반에서 노트북, 스마트폰, 태블릿과 같은 **엔드포인트** 디바이스를 보호
멀웨어와 같은 사이버 위협이 네트워크에 침투하는 것을 방지

암호화, 데이터 마스킹 기능을 제공하여 데이터 유출과 중요한 정보에 대한 무단 액세스를 방지



주요 구성 요소

SIEM(보안 정보 및 이벤트 관리)

SIEM 시스템을 사용하여 비즈니스 애플리케이션 및 네트워크 하드웨어에서 생성된 보안 경고를 실시간으로 분석. 이를 통해 비즈니스는 잠재적인 사이버 위협이 피해를 입히기 전에 신속하게 탐지하고 대응



SIEM(System Information and Event Management) ?

시스템은 기업의 IT 인프라에서 발생하는 보안 이벤트와 로그를 실시간으로 수집, 분석, 모니터링하는 보안 솔루션입니다.

보호 표면 식별 (Identifying the Protection Surface)

시스템 보안에서 보호해야 할 가장 중요한 자산이나 자원을 식별하고, 이를 집중적으로 보호

효율적인 보안 적용

최소 권한 원칙(Least Privilege Principle)을 적용할 때 유용

효율적인 자원 분배



이점

제로 트러스트 아키텍처의 이점



| 원격 및 하이브리드 작업 지원

언제 어디서나 모든 디바이스에서 안전하게 작업할 수 있도록 비즈니스 역량을 강화하세요.



| 클라우드로 마이그레이션

온-프레미스 솔루션에서 클라우드로 원활하게 전환하고 프로세스 전반에 걸쳐 보안 취약성을 줄일 수 있습니다.



| 위험 최소화

기존 보안 모델보다 더 효과적으로 데이터 침해를 방지하고, 악성 활동을 더 빠르게 식별하며, 더 빠르게 조치를 취할 수 있습니다.



| 직원 환경 개선

여러 개의 암호를 SSO(Single Sign-On) 또는 생체 인식으로 대체하여 리소스 액세스를 간소화하세요. 또한 BYOD(Bring Your Own Device) 모델을 지원하여 더 많은 자유와 유연성을 제공하세요.



| 규정 준수 용이성

포괄적인 보안 제어와 지속적인 모니터링을 통해 규정을 준수하고 민감한 비즈니스 데이터를 보호하세요.



| 보안 태세 강화

“절대 신뢰하지 말고 항상 확인하라”는 보안 접근 방식을 통해 사이버 공격으로 인한 잠재적 피해를 사전에 제한하고 네트워크의 측면 이동을 제한하세요.

실제 구현 사례



배경: VPN 없이도 안전하게 사내 리소스에 접근하도록 설계.
핵심: “네트워크 위치” 대신 “사용자 신원 + 디바이스 상태”를 기준으로 접근 통제.
효과: 원격근무, 외부 파트너, 다양한 디바이스 환경에서도 일관된 보안 정책 유지.

실제 구현 사례



Department of Defense (DoD) Zero Trust Reference Architecture

- 적용: 군사 네트워크 접근 시 사용자·기기·응용·데이터 계층별 검증 수행.
- 결과: 내부망 침입 시에도 구역 간 이동(lateral movement) 차단 성공.

관련 기술

분야	대표 솔루션 / 기술
인증 / 권한관리	Azure Active Directory, Okta, Ping Identity
네트워크 접근 제어	Zscaler, Palo Alto Prisma Access, Cisco Duo
로그/이벤트 분석	Splunk, IBM QRadar (SIEM), Elastic Security
보안 오케스트레이션	Cortex XSOAR, Microsoft Sentinel
데이터 보호	Symantec DLP, Microsoft Purview
디바이스 관리	Intune, CrowdStrike Falcon